UNIVERSIDADE FEDERAL DE SANTA CATARINA — UFSC
Programa de Pós-Graduação em Ciência da Computação (PPGCC)
Disciplina: Segurança – Web, Identidades e Nuvem (INE410124)
Professora: Carla Merkle Westphall

ROTEIRO DE ATIVIDADE PRÁTICA

Mini Aplicação Segura de Prontuários Médicos com OAuth2/OIDC (Keycloak), Assinatura JWS, Cifragem JWE e Acordo de Chaves Diffie-Hellman (ECDH-ES)

1. CENÁRIO DA APLICAÇÃO PRÁTICA

Uma clínica de telemedicina precisa integrar seu **Portal do Médico (Aplicação Cliente)** a um servidor de **Prontuário Eletrônico de Saúde (Resource Server)**. Como as consultas transitam por redes públicas e armazenam dados médicos altamente sensíveis (submetidos à LGPD e GDPR), a arquitetura do sistema deve atender rigorosamente aos seguintes requisitos de segurança:

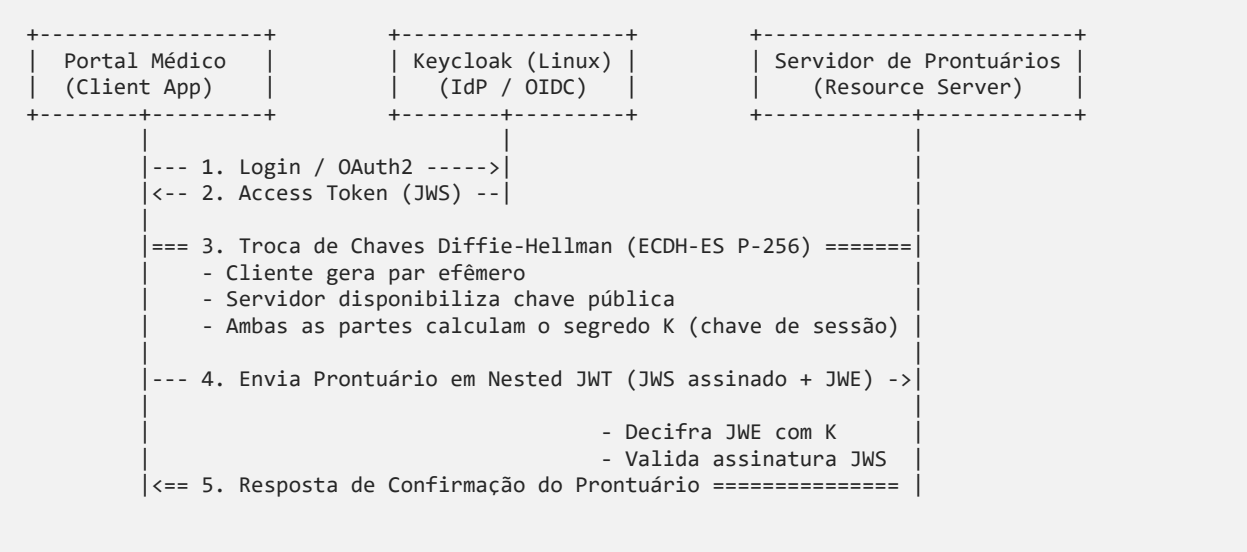
- **Autenticação Federada (Keycloak / OIDC):** O médico autentica-se no servidor Keycloak para obter o token de acesso OIDC e comprovar sua identidade e atributos de acesso.
- **Autenticidade e Não-Repúdio do Diagnóstico (JWS):** A prescrição e o laudo criados pelo médico devem ser assinados digitalmente via JSON Web Signature (JWS - RFC 7515) com a chave privada do profissional, garantindo integridade e não-repúdio.
- **Acordo de Chaves Diffie-Hellman entre as Partes (ECDH-ES):** Em vez de utilizar uma chave simétrica estática pré-compartilhada, o Portal do Médico e o Servidor de Prontuários devem estabelecer uma chave de sessão efêmera utilizando o protocolo Diffie-Hellman sobre Curvas Elípticas (ECDH-ES na curva P-256 / secp256r1 - RFC 7518).
- **Confidencialidade Ponta a Ponta (JWE / Nested JWT):** O laudo assinado (JWS) é encapsulado e criptografado via JSON Web Encryption (JWE - RFC 7516) utilizando a chave derivada pelo acordo Diffie-Hellman, gerando um token aninhado (Nested JWT - Sign-then-Encrypt).

2. OBJETIVOS DE APRENDIZAGEM

- Configurar e executar o servidor de identidades Keycloak em ambiente Linux (Docker/Podman ou standalone).
- Compreender e implementar o acordo de chaves Diffie-Hellman baseado em curvas elípticas (ECDH-ES) conforme a especificação RFC 7518 (JWA).
- Implementar o padrão Nested JWT (Sign-then-Encrypt), garantindo que a assinatura JWS seja gerada primeiro e, em seguida, cifrada no envelope JWE de 5 partes.
- Analisar o tráfego de rede demonstrando a opacidade dos dados sensíveis e a verificação do conjunto de chaves JWK Set (RFC 7517).

3. ARQUITETURA DA SOLUÇÃO E FLUXO TÉCNICO

A figura a seguir descreve a sequência de interações lógicas entre o Portal do Médico, o servidor Keycloak no Linux e o Servidor de Prontuários:



4. ROTEIRO DE IMPLEMENTAÇÃO PASSO A PASSO

Etapa 1: Infraestrutura de Identidade no Linux (Keycloak)

- Iniciar o servidor Keycloak em contêiner no Linux (sugestão de comando):

  ```
  docker run -d --name keycloak_med --net=host -e KEYCLOAK_ADMIN=admin -e KEYCLOAK_ADMIN_PASSWORD=admin quay.io/keycloak/keycloak:latest start-dev
  ```

- Acessar o console administrativo (http://localhost:8080), criar o Realm 'Telemedicina-Realm' e cadastrar o cliente 'portal-medico-app'.
- Cadastrar um usuário de teste (ex: dr.silva) com permissões de acesso e definir suas credenciais.

Etapa 2: Acordo de Chaves Diffie-Hellman (ECDH-ES)

- Implementar a troca de chaves Diffie-Hellman efêmera estática (ECDH-ES) utilizando a curva P-256 (secp256r1):
- O cliente gera um par de chaves efêmeras (nA, PA) e insere a chave pública no cabeçalho do JWE via parâmetro 'epk' (Ephemeral Public Key).
- O servidor utiliza sua chave privada estática (nB) e a chave pública efêmera (PA) para derivar o segredo K = nB * PA.
- A função de derivação de chave KDF determina a Content Encryption Key (CEK) simétrica (A128GCM ou A256GCM).

Etapa 3: Construção do Token Aninhado (JWS + JWE / Nested JWT)

- Passo 1 (Assinatura JWS): O Portal do Médico constrói o payload com os dados médicos (paciente_id, diagnostico, prescricao) e gera um JWS de 3 partes (Header.Payload.Signature) assinado com ES256 ou RS256.
- Passo 2 (Cifragem JWE): A string JWS gerada no Passo 1 é utilizada como entrada (plaintext) para a cifra JWE.
- O envelope JWE final é serializado no formato compacto de 5 partes: ProtectedHeader.EncryptedKey.IV.Ciphertext.AuthTag
- Parâmetros de Cabeçalho JWE Obrigatórios: alg: 'ECDH-ES', enc: 'A128GCM', cty: 'JWT' (indicando que o payload interno é outro JWT/JWS).

Etapa 4: Processamento no Servidor de Prontuários

- O servidor recebe a mensagem JWE de 5 partes via requisição HTTP POST /api/prontuarios.
- Decifra o envelope JWE derivando a chave simétrica através do Diffie-Hellman (usando o 'epk' do cabeçalho JWE + sua chave privada estática).
- Extrai a string JWS interna e valida a assinatura digital utilizando a chave pública do médico obtida do Keycloak / JWK Set.

5. ENTREGÁVEIS DOS ALUNOS

Repositório de Código-Fonte: Link para repositório (GitHub/GitLab) contendo o código-fonte da aplicação cliente, servidor de prontuários e instruções de execução (Dockerfile ou scripts Shell).

Relatório Técnico em PDF: Documento em PDF estruturado com as seguintes evidências e análises:

- **Screenshots da Configuração:** Comprovação da execução do Keycloak no Linux, criação do Realm, Client e Usuários.
- **Inspeção de Tokens e Estrutura:** Exibição e quebra detalhada do JWS assinado (3 partes) e do JWE criptografado (5 partes), destacando os campos 'alg: ECDH-ES', 'enc', 'cty: JWT' e 'epk'.
- **Análise Teórica de Segurança:** Discussão explicando como o Diffie-Hellman garante o sigilo do canal de transmissão e porque a assinatura JWS interna é indispensável para evitar ataques de Man-in-the-Middle (autenticidade das partes).

6. AVALIAÇÃO (10,0 PONTOS)

Critério	Descrição Detalhada	Pontuação
Keycloak no Linux	Instalação funcional no Linux, criação de Realm, Client OIDC e parametrização de usuários/chaves.	1,5 pts
Integração OIDC / JWS	Autenticação via Keycloak e geração correta da assinatura digital JWS no laudo médico.	2,0 pts
Diffie-Hellman (ECDH-ES)	Implementação do acordo de chaves usando a curva P-256 e inclusão do parâmetro 'epk' no cabeçalho JWE.	2,5 pts
Cifragem JWE & Nested JWT	Encapsulamento do JWS no envelope JWE de 5 partes com parâmetro 'cty: JWT' e decifragem correta.	2,5 pts
Relatório, Análise Técnica & Apresentação	Clareza teórica, screenshots comprovatórios, análise de tráfego de rede e discussão sobre proteção MiTM.	1,5 pts